

Enrico Bravi

enrico.bravi@polito.it

Module B – Social Engineering and Digital Identity

B1 – Human Factor



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



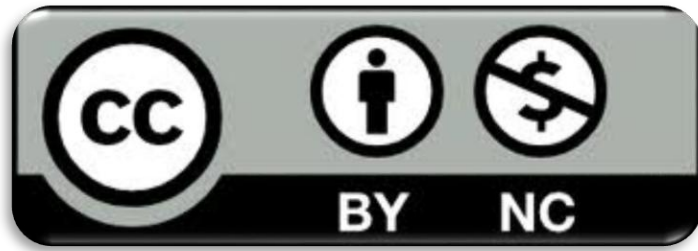
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.

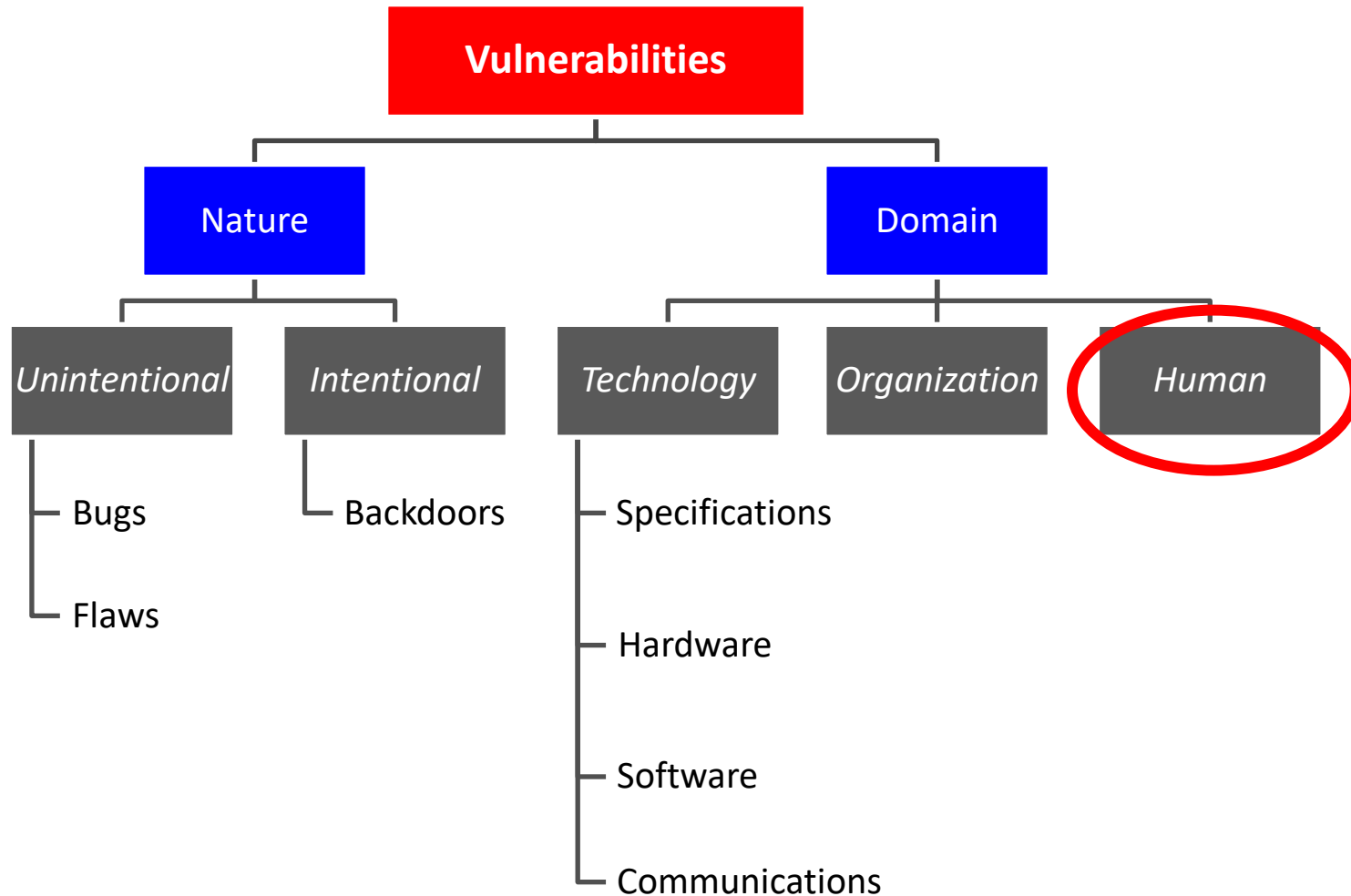


Learning Goals

- introducing the concept of **Social Engineering**
- analyzing the main motivations that make it possible



Vulnerabilities Classification



Human Factor

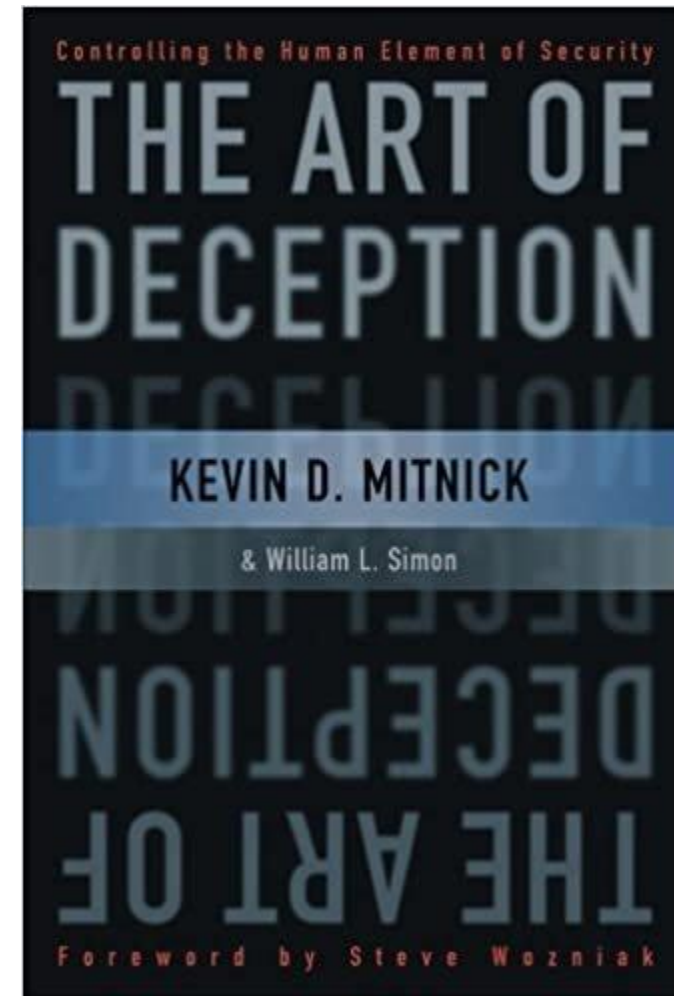
- humans remain the weakest link in cybersecurity
- they can be manipulated to perform malicious operations (against themselves!)
 - downloading software
 - visiting websites
 - sending money to criminals
 - ...





*“No matter how strong your firewalls,
intrusion detection systems, encryption,
antivirus, you are still the weakest link in
cybersecurity!
People are more vulnerable than computers”*

[Kevin D. Mitnick & William L. Simon – The
Art of Deception]





Motivation

- **lack of awareness** and culture from **ALL** the involved people/stakeholders
 - people not involved in technical operations often believe that cybersecurity involves only few persons playing with laptops in a basement
- **misperception** of risks
 - usually attackers exploit information considered meaningless by users
- this opens the doors to **Social Engineering**
 - it doesn't require to be a hacker or a programmer, but most of the time it requires to be able to send an email



Social Engineering (I)



- the art and science of making people do what you want them to do

[Harl - People Hacking: The Psychology of Social Engineering]



Social Engineering (II)



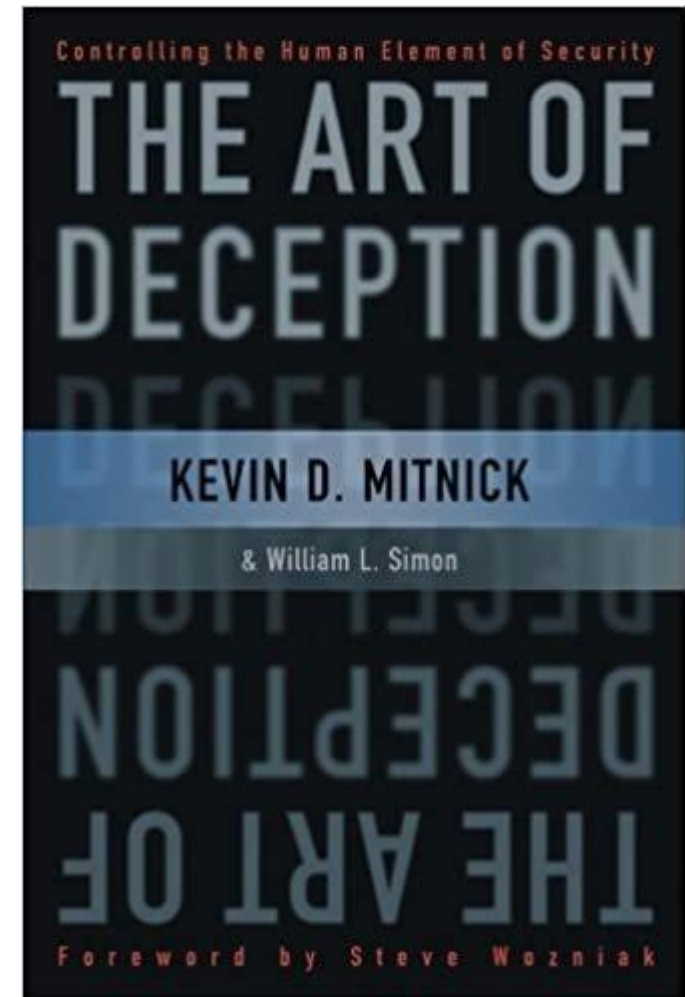
- combination of sociological, psychological, and information-gathering techniques used to manipulate people with the ultimate goal of:
 - **persuading** them to release sensitive information (e.g., passwords, credit cards details)
 - performing actions that do not comply with normal security measures (e.g., visiting malicious websites, open attachments in suspicious emails)
 - getting them to act in a way that allows **unauthorized** access or use of systems, networks, data, information (e.g., opening physical doors, borrowing sensitive devices)

Social Engineering (III)



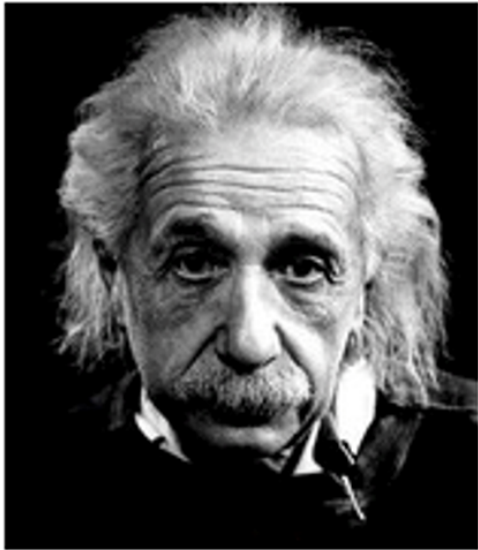
- *"The use of one's influence and persuasion skills to deceive or manipulate others into believing that the social engineer is what she/he is not."*

[Kevin D. Mitnick & William L. Simon – The Art of Deception]





Social Engineering – How is it possible?



“Two things are infinite: the universe and human stupidity; and I'm not sure about the universe.”

– Albert Einstein



Human Factor Analysis

- humans:
 - are “**complex**” systems, and criminals can **manipulate** victims’ **emotions** and **instincts** in ways proven to drive people to perform actions that are not in their best interests
 - have **vulnerabilities** mostly based on:
 - behavioral traits
 - good faith exercised by individuals in social relationships
 - cognitive bias



Dual Process Theory (I)

- Peter Wason and Jonathan St B. T. Evans suggested dual process theory in 1974
- assumes that the decision-making process is the result of the interaction between two distinct systems:
 - *system 1*: automatic and unconscious cognitive activity (fast, instinctive, and emotional)
 - *system 2*: conscious and rational cognitive activity (slow, logical, and deliberate)



Dual Process Theory (II)

System 1 (Intuitive)

- operates automatically
- is fast
- does not require cognitive effort
- does not require voluntary control
- is always working and active

System 2 (Analytical)

- is activated when faced with challenging mental activities
- is slow
- requires greater cognitive effort
- requires voluntary control
- requires maximum concentration
- the ability to keep it active is easily exhausted



System 1 – Example

- detecting emotion in a face
- when you look at a photo of someone yelling, you don't "calculate" their mood, but you instantly know they are angry
- this process is characterized by:
 - **awareness**: you didn't "try" to see the anger; it just happened
 - **efficiency**: it took zero mental effort



System 2 – Example

- solving 17×24
- the answer doesn't just “pop” into your head, but you have to consciously choose to start the problem, hold the numbers in your working memory, and follow a sequence of rules
- this process is characterized by:
 - **intentionality**: you must consciously “start up” this process
 - **capacity**: if someone starts talking to you while you're doing the math, you'll likely lose your place because System 2 has limited resources
 - **rule-based**: you are following a logical, step-by-step analytical path



Cognitive Biases

- cognitive biases interfere with the functioning of intuitive thinking, altering the perception of many events

Journal of Personality and Social Psychology
1999, Vol. 77, No. 6, 1121-1134

Copyright 1999 by the American Psychological Association, Inc.
0022-3514/99/\$3.00

Unskilled and Unaware of It: How Difficulties in Recognizing One's Own Incompetence Lead to Inflated Self-Assessments

Justin Kruger and David Dunning
Cornell University

People tend to hold overly favorable views of their abilities in many social and intellectual domains. The authors suggest that this overestimation occurs, in part, because people who are unskilled in these domains suffer a dual burden: Not only do these people reach erroneous conclusions and make unfortunate choices, but their incompetence robs them of the metacognitive ability to realize it. Across 4 studies, the authors found that participants scoring in the bottom quartile on tests of humor, grammar, and logic grossly overestimated their test performance and ability. Although their test scores put them in the 12th percentile, they estimated themselves to be in the 62nd. Several analyses linked this miscalibration to deficits in metacognitive skill, or the capacity to distinguish accuracy from error. Paradoxically, improving the skills of participants, and thus increasing their metacognitive competence, helped them recognize the limitations of their abilities.



Cognitive Bias as a Vulnerability

- the **social engineer**, via various techniques and strategies, exploits the onset of cognitive bias in the victim and uses these weaknesses to achieve his/her goals



The “Urgent Wire Transfer” Phishing Email

- an employee in the finance department receives an email that appears to be from the company’s CEO
- the email says:

“I’m in a board meeting and can’t talk, but we need to secure this vendor contract immediately or we’ll lose the deal. Please wire \$50,000 to the attached account details right now. I need a confirmation in 10 minutes.”



How it Exploits Cognitive Biases (I)

- the attacker isn't hacking the computer; they are hacking the **cognitive biases** that govern System 1:
 - **authority:** humans have an instinctive tendency to obey figures of authority, and when System 1 sees a “message from the CEO”, it triggers a compliance response before System 2 can ask, *“Is this email address actually correct?”*



How it Exploits Cognitive Biases (II)

- **urgency:** by adding a 10 minutes deadline, the attacker creates a high-pressure environment, where high stress and urgency **suppress System 2**, because System 2 is slow and resource-heavy, the brain relies on the “fast” System 1 to resolve the stress quickly by simply complying
- **loss risk:** the threat of “losing the deal” triggers a fear of loss, and System 1 is evolutionarily wired to prioritize avoiding a loss over gaining a reward, making the employee act impulsively to prevent the negative outcome



Social Engineering - Target

- each of us can be the chosen victim
- primary target is typically help desk, secretarial, or support staff

“Hacking” People

- the social engineer hacks people because, very often, hacking a human being is easier than hacking a computer system
- why spending time looking for vulnerabilities in a system when you can fraudulently get its password?

